



Cyberster Blue Team Internship

WEEK 06 Report

Haris Zamir
CSI-B1-487

1. Executive Summary

On May 1, 2026, a high-severity insider threat incident was simulated and investigated on a Windows 10 endpoint (`DESKTOP-IBC1SLT`). An internal actor successfully staged a confidential database file, obfuscated the data using Base64 encoding to evade traditional signature-based detection, and exfiltrated the payload to an unauthorized listener on an internal Kali Linux machine. The attacker subsequently performed anti-forensic measures by deleting the staging directory. The incident was detected via **Wazuh File Integrity Monitoring (FIM)**, and the exfiltrated data was successfully recovered and decoded for impact assessment.

2. Infrastructure & Network Setup (The "Bridge" Phase)

Before the investigation, the lab environment was transitioned from a local-only NAT setup to a distributed physical network to increase simulation realism.

- **Physical Architecture:** Two separate laptops connected over a local Wi-Fi network.

- **Logical Network:** All Virtual Machines (pfSense, Kali, Ubuntu Manager, and Windows 10) were bridged to the physical Wi-Fi cards using **VMware VMnet0**.
- **Subnet Isolation:** A static IP scheme (**192.168.20.0/24**) was implemented to isolate lab traffic from the primary home network (**192.168.18.0/24**).
- **pfSense Integration:** Acted as the default gateway (**192.168.20.1**), ensuring all inter-VM traffic could be monitored.

3. Detection and Analysis (Technical Deep-Dive)

The investigation utilized Wazuh SIEM and forensic decoding tools to reconstruct the attacker’s timeline.

Timestamp (Approx)	Attacker Action	MITRE ATT&CK Technique	Evidence Source
13:29:28	Created Client_Database.txt	T1074 (Data Staging)	Wazuh FIM (Rule 553 Path)
13:29:35	Encoded to system_cache.b64	T1027 (Obfuscation)	Wazuh FIM (Rule 553 Path)
13:32:00	Exfiltration via HTTP POST	T1048 (Alternative Protocol)	Kali nc Listener Log
13:36:24	Directory Wipe (C:\Espionage)	T1070 (Indicator Removal)	Wazuh FIM (Rule 553)

Analysis of the Timeline

- **Technique T1074:** The attacker utilized a temporary staging directory, `C:\Espionage`, to collect sensitive information before moving it off-system.
- **Technique T1027:** By using `certutil.exe` to encode the database into Base64, the attacker attempted to bypass simple keyword-based network filters that might alert on the word "password" or "account".
- **Technique T1048:** The exfiltration occurred over port **8080** via an HTTP POST request, which is an alternative protocol often used to blend in with legitimate web traffic.
- **Technique T1070:** The final deletion of the staging folder triggered the **Rule 553** alerts, providing the critical forensic evidence needed to confirm what files were present during the attack

4. Containment, Eradication, and Recovery

To mitigate the threat in a production environment, the following actions were defined:

- **Containment:** The compromised user account on `DESKTOP-IBC1SLT` was immediately disabled to prevent further access. Outbound traffic on port 8080 was blocked at the pfSense firewall.
- **Eradication:** A full system scan was conducted to ensure no persistent shells or "Backdoor" accounts were created. The `C:\Espionage` directory was audited for hidden system attributes.
- **Recovery:** System state was restored from a known-good backup. Password resets were forced for all accounts found in the exfiltrated "Client Database".

5. Post-Incident Activity & Detection Engineering

To prevent future occurrences, a custom detection rule was developed to catch the staging of **.b64** files in sensitive directories.

Custom Wazuh Rule (**local_rules.xml**)

```
GNU nano 7.2 /var/ossec/etc/rules/local_rules.xml *
</mitre>
</rule>

<rule id="100003" level="12" frequency="3" timeframe="120">
  <!--<if_matched_sid>5760</if_matched_sid-->
  <!--<if_matched_sid>5716</if_matched_sid-->
  <if_matched_group>authentication_failed</if_matched_group>
  <same_source_ip />
  <description>Possible SSH Brute Force Attack Detected</description>
  <mitre>
    <id>T1110</id>
  </mitre>
</rule>

<!--
<rule id="100004" level="7">
  <if_group>windows_eventchannel</if_group>
  <field name="win.system.eventID">2003|2102|2100</field>
  <description>USB Storage Device Inserted on $(win.system.computer)</description>
</rule>
-->

<rule id="100001" level="0">
  <if_sid>651</if_sid>
  <description>Silence Active Response noise for Lab</description>
</rule>

<rule id="100005" level="3">
  <if_sid>550</if_sid>
  <description>Silence FIN noise during lab testing</description>
</rule>

  <rule id="100006" level="10">
    <if_sid>550, 554</if_sid>
    <field name="syscheck.path">C:\\Espionage\\</field>
    <match>\\.b64$</match>
    <description>Critical Alert: Base64 Encoded File Detected in Espionage Directory - Possible Data Exfiltration Staging.</description>
    <mitre>
      <id>T1027</id>
    </mitre>
  </rule>

</group>
```

```
<group name="syscheck,insider_threat,">
  <rule id="100001" level="10">
    <if_sid>550, 554, 553</if_sid>
    <field name="syscheck.path">C:\\Espionage\\</field>
    <match>\\.b64$</match>
    <description>Critical: Base64 Encoded File Detected in Sensitive
Directory - Possible Exfiltration Staging.</description>
    <mitre>
      <id>T1027</id>
    </mitre>
  </rule>
</group>
```

Logic: This rule triggers a Level 10 alert (high priority) whenever a file with a **.b64** extension is created or modified within the monitored path.